

BEFORE Placeholder

AFTER

Intake SLA & Prioritisation Standard — Third-Party Security Program

Document classification: Internal

Document owner: Third-Party Security Program Owner

Version: 0.1

Effective date: _____

Review cadence: Quarterly (performance) / Annually (standard)

1. Purpose

This document defines service levels (SLAs) and prioritisation rules for processing third-party security intake requests, performing tiering/triage, and completing due diligence decisions.

2. Scope

Applies to all supplier intake requests submitted via the approved intake channel/template and routed to the Third-Party Security Program.

3. Assumptions and dependencies

SLAs apply when:

- the intake form is complete, and
- the Business Service Owner (BSO) provides timely responses, and
- the supplier provides requested evidence within agreed timeframes.

Delays caused by incomplete intake details, supplier non-responsiveness, contract negotiation, or late scope changes pause the SLA clock and must be recorded.

4. Priority levels

Priority is determined by (a) supplier tier, (b) time-to-go-live, and (c) exposure (privilege/connectivity/data).

P0 — Urgent / Critical timeline

Used when:

- go-live is within 10 business days, AND
- supplier is Critical OR the request involves privileged access, inbound connectivity, or sensitive data processing.

P1 — High

Used when:

- supplier is Critical, OR
- go-live is within 20 business days.

P2 — Standard

Used when:

- supplier is Important, and go-live is > 20 business days.

P3 — Low

Used when:

- supplier is Low tier and/or no integration/data processing is confirmed.

5. SLAs (program targets)

All SLAs are measured in business days.

5.1 Intake acknowledgement

- P0/P1/P2/P3: **1 business day** Definition: confirmation that the request is received, logged, and assigned a reference/owner.

5.2 Triage and tiering decision

- P0: **2 business days**
- P1: **3 business days**
- P2: **5 business days**
- P3: **10 business days** Definition: tier recorded (Critical/Important/Low), evidence pack identified, required stakeholders assigned (IT/Platform, DPO, Legal, etc.).

5.3 Evidence pack issuance to supplier

- P0: **1 business day** after triage
- P1: **2 business days** after triage
- P2: **3 business days** after triage
- P3: **5 business days** after triage Definition: evidence pack sent by Procurement (or delegated role) with return date and contact details.

5.4 Initial security review (upon receipt of supplier response)

- P0: **3 business days**
- P1: **5 business days**
- P2: **7 business days**
- P3: **10 business days** Definition: review completed, gaps identified, and questions/actions issued back to supplier/BSO.

5.5 Due diligence decision (Approve / Conditional / Defer/Reject)

- P0: **5 business days** from complete evidence receipt
- P1: **10 business days** from complete evidence receipt
- P2: **15 business days** from complete evidence receipt
- P3: **20 business days** from complete evidence receipt Definition: decision recorded with conditions/actions and owners.

Note: for Critical suppliers requiring Senior Residual Risk Acceptance or complex contracting, the decision may be "Approved with Conditions" pending formal approvals.

6. SLA clock rules (pause/resume)

The SLA clock is paused when:

- intake form is incomplete or materially inaccurate,
- scope changes materially after triage (new data types, new integrations, privileged access),
- supplier delays providing evidence beyond agreed dates,
- legal/privacy negotiation introduces material delays outside program control,
- a security incident or urgent priority conflict requires reallocation.

Pause/resume events MUST be recorded with date/time and reason.

7. Intake quality requirements (to avoid rework)

Intake submissions MUST include:

- clear service description and business owner,
- target go-live date,
- integration type (SSO/API/agent/connectivity),
- data types (especially personal data),
- any privileged access requirements,
- criticality assessment (client/regulatory impact).

Incomplete submissions are returned to the requestor within the acknowledgement SLA.

8. Prioritisation rules (when demand exceeds capacity)

When multiple requests compete:

1. P0 requests are handled first.

2. Requests involving **privileged access, inbound connectivity, or sensitive data at scale** are prioritised within the same tier.
3. Renewals for Critical suppliers are prioritised ahead of new Low suppliers.
4. Low-tier requests may be deferred if controls indicate low exposure and no imminent deadline.

9. Escalation

Escalate to the Third-Party Security Program Owner when:

- a P0 request is at risk of missing SLA due to internal constraints,
- a business owner requests bypassing minimum requirements or evidence packs,
- the supplier refuses baseline commitments (MFA, logging, incident notification) for Critical scope,
- repeated scope changes are causing rework.

10. Metrics

SLA performance is tracked via KPIs:

- median triage time by priority,
- median decision time by priority,
- % requests paused and top pause reasons,
- backlog size by tier and age. See: ``metrics/`` and the monthly dashboard template.